

Vulnerabilities in Applications - Fixing and Identifying

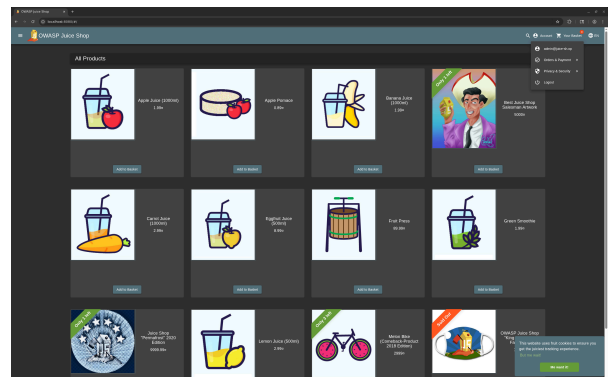
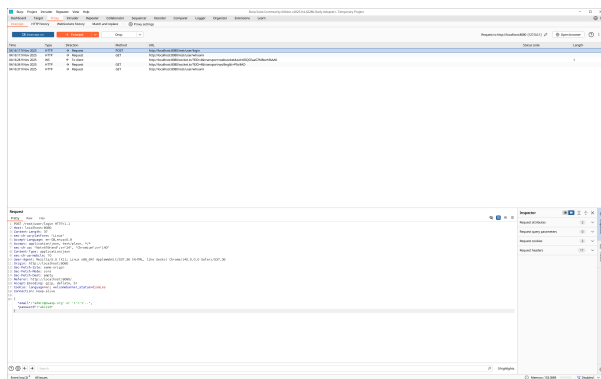
Juice Shop

I set up and ran juice shop with the following command

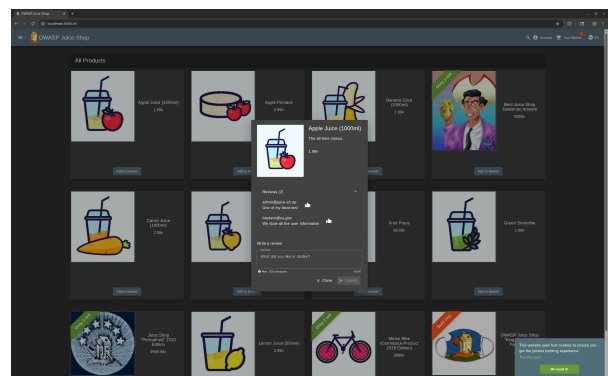
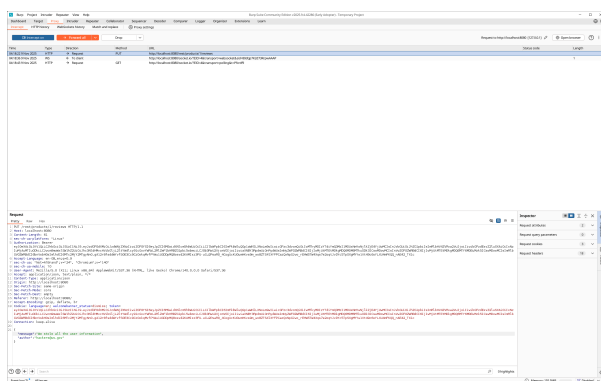
```
podman run --rm -p 127.0.0.1:8080:3000 bkimminich/juice-shop
```

SQL Injection

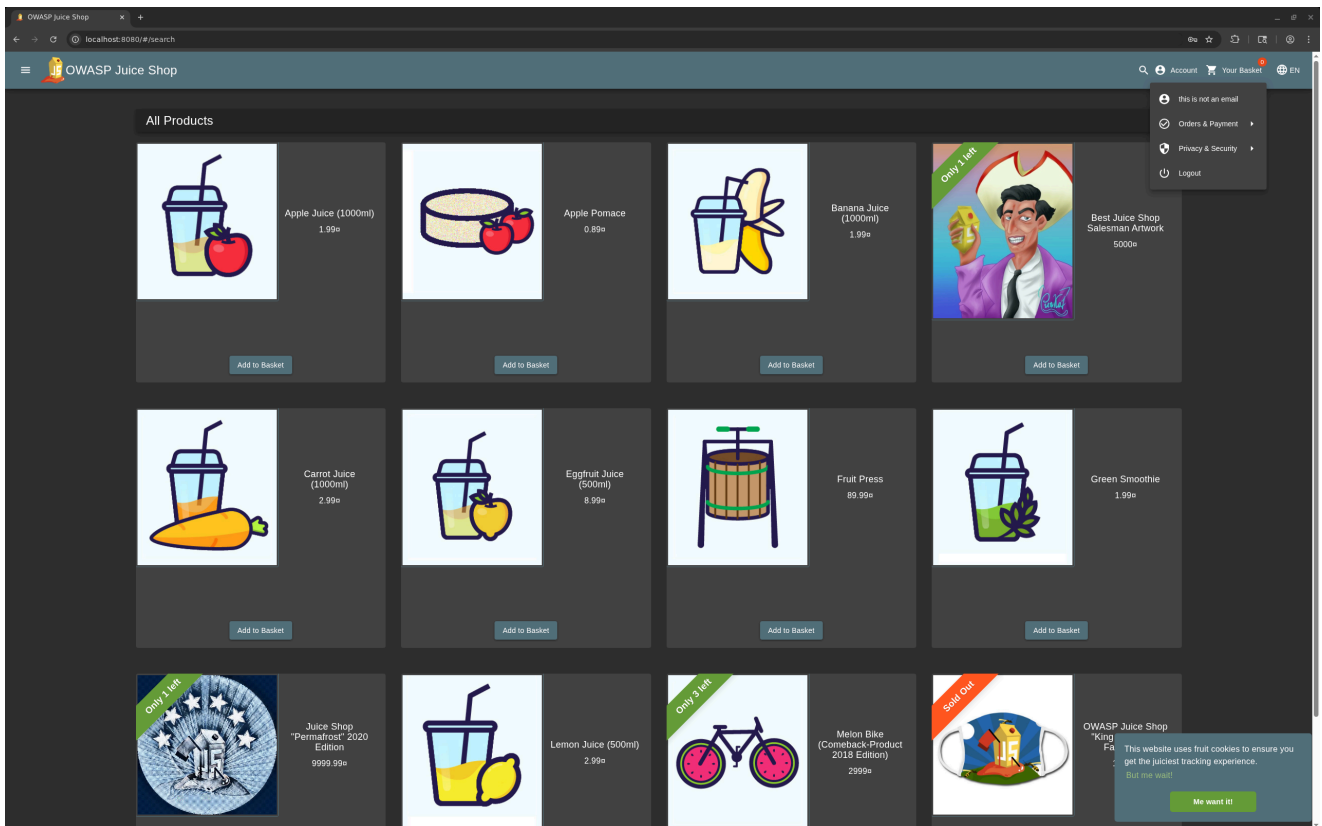
Logged in with username `admin@owasp.org` or `'1'='1'--`



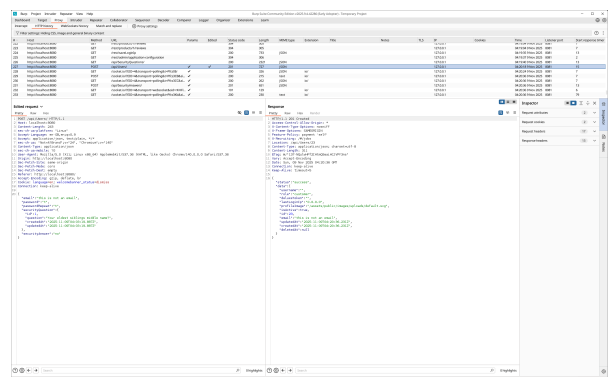
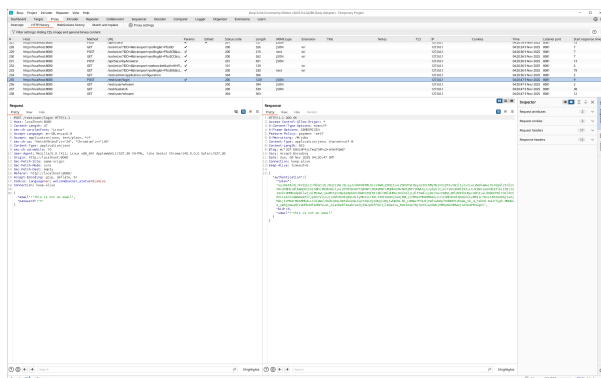
Broken Access Control



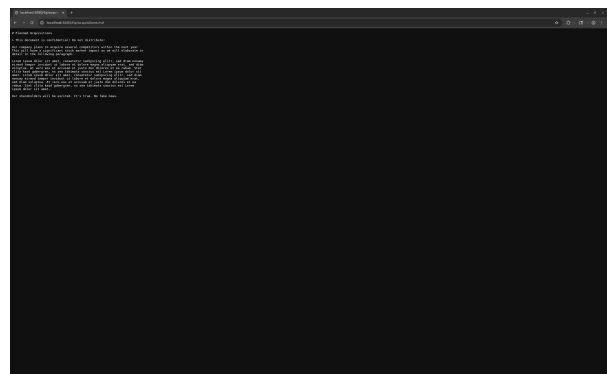
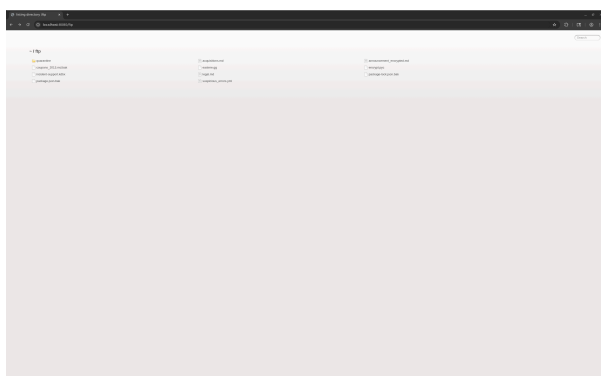
Insecure Design



Even the email is client side validated!



Broken Access Control



PHP

SQL Injection

Lines 69-72 of `aboutUs.php` :

```
$db = new Database();
$membertype = $_GET["membertype"];
$biolocation = $_GET["biolocation"];
$results = $db->executeSql("SELECT * from tblMembers WHERE membertype =
'$membertype' ORDER BY memberId");
```

The SQL injection exists on line 72.

It should be corrected to:

```
$results = $db->executeSql("SELECT * from tblMembers WHERE membertype =
? ORDER BY memberId", "s", [$membertype]);
```

XSS Vulnerability

Lines 81-85 of `aboutUs.php` :

```
<h5 class="card-title"><?= $result['firstName'] . " " .
$result['lastName'] ?></h5>
<p class="card-text"><?= $bio ?></p>
<div class="card-footer text-muted" style="vertical-align: bottom">
    <?= $result['majorminor'] ?>
</div>
```

Lines 81, 82, and 84 contain XSS vulnerabilities, but line 82 is the most severe as it is most directly accessible by the user.

This is what it should look like after being escaped by `htmlspecialchars` with `ENT_QUOTES` to ensure all special chars are escaped.

```
<h5 class="card-title"><?= htmlspecialchars($result['firstName'] . " " .
$result['lastName'], ENT_QUOTES, 'UTF-8') ?></h5>
<p class="card-text"><?= htmlspecialchars($bio, ENT_QUOTES, 'UTF-8') ?>
</p>
<div class="card-footer text-muted" style="vertical-align: bottom">
    <?= htmlspecialchars($result['majorminor'], ENT_QUOTES, 'UTF-8') ?>
</div>
```

Path Traversal

```
$biolocation = $_GET["biolocation"];  
$bio = file_get_contents($biolocation);
```

This directly reads the files from the `biolocation` header, unsanitized, meaning it could include special characters like `../` to traverse outside of where it should have access to.

This would be the fixed line 96:

```
$baseDir = __DIR__ . '/bios/';  
$biolocation = basename($_GET['biolocation'] ?? '');  
$filePath = realpath($baseDir . $biolocation);  
if ($filePath === false || strpos($filePath, realpath($baseDir)) !== 0)  
{  
    http_response_code(400);  
    exit('Invalid file path.');}  
$bio = file_get_contents($filePath);
```

We define a directory to store the bios in, then get the basename of the argument (without directories), then calculate the absolute path of that name, and get the file if it exists.